

■ secsuite security report

Solana

Profile	default	Status	GATE PASSED
Active checks	yes	Gate threshold	high
Started	2026-09-04 03:27	Duration	3.5s

Summary

Findings: **1 medium** · **2 low** · **1 info**

Checks: 20 passed · 3 found issues · 2 skipped · 0 errored

Findings

MEDIUM No clickjacking protection

owasp_checks · A05:2021 · CWE-1021

■ <https://solanafireplaces.com/>

Neither X-Frame-Options nor a CSP frame-ancestors directive is set, so the page can be embedded in a frame for clickjacking.

Fix: Set `X-Frame-Options: DENY` or `Content-Security-Policy: frame-ancestors 'none'`.

LOW Missing security header: x-content-type-options

owasp_checks · A05:2021 · CWE-693

■ <https://solanafireplaces.com/>

The response does not set the `x-content-type-options` header.

Fix: Send `X-Content-Type-Options: nosniff`.

LOW Missing security header: referrer-policy

owasp_checks · A05:2021 · CWE-693

■ <https://solanafireplaces.com/>

The response does not set the `referrer-policy` header.

Fix: Send `Referrer-Policy: strict-origin-when-cross-origin`.

INFO No security.txt

owasp_checks · A05:2021 · CWE-200

■ <https://solanafireplaces.com/.well-known/security.txt>

No security.txt is published, so security researchers have no documented way to report vulnerabilities.

Fix: Publish [./well-known/security.txt](https://solanafireplaces.com/.well-known/security.txt) with a Contact field (see securitytxt.org).

Checks performed

Status	Check	What it tests / outcome
PASS	Target reachability	Confirm the target responds before running checks. <i>HTTP 200 from https://solanafireplaces.com/</i>
SKIP	Protected endpoint reachable without auth A01:2021	Requests each configured protected path with no credentials and checks it is rejected (401/403), not served. <i>not applicable to web targets</i>
PASS	Dangerous HTTP method enabled A01:2021	Sends TRACE/TRACK requests to see if the server accepts them (can enable Cross-Site Tracing). <i>passed — no issue detected</i>
PASS	HTTP not redirected to HTTPS A02:2021	Checks that a plain-HTTP request is redirected to HTTPS instead of served in the clear. <i>passed — no issue detected</i>

Status	Check	What it tests / outcome
PASS	Cookie missing security flags A02:2021	Inspects Set-Cookie headers for the Secure, HttpOnly, and SameSite flags on session/auth cookies. <i>passed — no issue detected</i>
PASS	Reflected input (possible XSS) A03:2021	Sends a marker string in configured parameters and checks whether it is reflected unencoded into HTML. <i>passed — no issue detected</i>
PASS	SQL error triggered by quote injection A03:2021	Injects a single quote into configured parameters and looks for database error signatures in the response. <i>passed — no issue detected</i>
ISSUE	Missing security header A05:2021	Checks the response for HSTS, CSP, X-Content-Type-Options, X-Frame-Options, and Referrer-Policy headers. <i>2 issue(s) found</i>
PASS	Server/framework version disclosed A05:2021	Inspects Server / X-Powered-By headers for software versions that aid an attacker. <i>passed — no issue detected</i>
SKIP	Django DEBUG appears enabled A05:2021	Requests a non-existent path and checks whether a Django debug traceback (DEBUG=True) is rendered. <i>not applicable to web targets</i>
PASS	Sensitive file exposed A05:2021	Probes common leak paths (.env, .git/config, backups, credentials) to see if any are publicly served. <i>passed — no issue detected</i>
PASS	Overly permissive CORS A05:2021	Sends a cross-origin request and checks whether the response reflects arbitrary origins or allows "*" with credentials. <i>passed — no issue detected</i>
PASS	No rate limiting on login A07:2021	Sends a small burst of failed logins to the configured endpoint and checks for a rate-limit/lockout (429/423). <i>passed — no issue detected</i>
PASS	Login reveals whether a user exists A07:2021	Compares login responses for a known vs unknown username to detect a user-enumeration oracle. <i>passed — no issue detected</i>
PASS	Session cookie not fully protected A07:2021	Checks that session/auth cookies set HttpOnly (blocks JS theft), Secure (blocks sniffing), and SameSite. <i>passed — no issue detected</i>
PASS	Weak or predictable session ID A07:2021	Collects a few fresh session cookies and checks the identifier is long and high-entropy (hard to guess). <i>passed — no issue detected</i>
PASS	Session ID exposed in URL A07:2021	Checks redirects and page links for a session ID carried in the URL (leaks via Referer, history, logs). <i>passed — no issue detected</i>
PASS	Session fixation (ID not rotated at login) A07:2021	Logs in with configured credentials and checks the session ID changes afterwards; if not, a pre-set ID can be fixed. <i>passed — no issue detected</i>
PASS	Mixed content on HTTPS page A05:2021	On an HTTPS page, looks for sub-resources (scripts, styles, images) loaded over plain http://. <i>passed — no issue detected</i>
PASS	External script/style without Subresource Integrity A08:2021	Flags cross-origin <script>/<link> resources loaded without an integrity (SRI) hash. <i>passed — no issue detected</i>
ISSUE	No clickjacking protection A05:2021	Checks the page can't be framed by others — via X-Frame-Options or a CSP frame-ancestors directive. <i>1 issue(s) found</i>
PASS	Weak Content-Security-Policy A05:2021	When a CSP is present, checks it doesn't defeat itself with unsafe-inline, unsafe-eval, or wildcard sources. <i>passed — no issue detected</i>

Status	Check	What it tests / outcome
PASS	JavaScript source map exposed A05:2021	Fetches the page's own scripts and checks whether their .map source maps are publicly served (leaks source). <i>passed — no issue detected</i>
ISSUE	No security.txt A05:2021	Checks for a /.well-known/security.txt describing how to report vulnerabilities (best practice). <i>1 issue(s) found</i>
PASS	Open redirect A01:2021	Sends an external URL in common redirect parameters (next, url, redirect...) and checks if the site redirects off-site. <i>passed — no issue detected</i>